

EPSS Meets UPS:

Stable Levels, Spikes, and the Price of Early Attention

(Paper III in the “Meets Patch Queues” series)

Sergey Gordeychik
CyberOK Research
gordey@cyberok.ru

January 2026

Abstract

EPSS is widely used as a remediation gate: “patch everything above a threshold.” In earlier work we showed that EPSS-only gates face hard operational limits when judged against exploited ground truth and finite patch capacity. This paper asks a narrower and more pragmatic question: can EPSS still be useful as an *early-warning signal* inside an evidence-timeline phase model (UPS), without pretending it is a ground truth oracle?

Using weekly EPSS snapshots from 2025 and UPS timelines, we define an *early true positive* as an EPSS alert that occurs strictly before the vulnerability reaches an Urgent Patch floor stage within the 2025 evaluation window. We evaluate percentile-threshold rules with optional persistence (k consecutive weeks) and an optional acceleration rule (Δ percentile spike). We report a Pareto trade-off between early recall and workload inflation measured as false positives per positive (FP/positive), plus lead-time distributions for true early alerts.

On the Urgent Patch floor ground truth (positives $N = 308$), we obtain three practical operating points: WATCH+ (broad coverage, higher noise), TRACK+ (stable-high regime with $k = 2$), and PREPARE+ (high-confidence extreme tail). An optional PREPARE_ACCEL+ rule captures abrupt percentile jumps with very low induced workload. We additionally evaluate a complementary early-attention channel (CIRCL sightings aggregated from news and community sources) on a KEV-late subset, and propose boundary rules to use such signals as bounded PREP accelerators. The cynical but useful conclusion: EPSS is not a patch policy by itself, but it can be a credible *queue admission hint* when stability constraints and explicit load budgets are treated as first-class citizens.

1 Introduction (or: you can patch the future, but you can only schedule one week at a time)

Vulnerability management is a service system with finite throughput and infinite ambition. Scores promise a shortcut: compress the world into a scalar, sort descending, patch until you run out of calendar. Reality responds with a maintenance window.

In Paper II we studied EPSS as a stand-alone intake gate[1] and showed a recurring failure mode: even under generous capacity, the decision-time outcome for confirmed exploited vulnerabilities can be dominated by *signal timing and availability*, not by staffing. In Paper I we introduced UPS, a phase model[2] that treats urgency as an evidence timeline rather than a static score, and showed that phase-based admission can shift work left under capacity and cadence constraints.

This paper (Paper III) is about reconciliation. We stop asking EPSS to be a policy, and ask it to be what it is good at: a probabilistic hint with a weekly cadence. We integrate EPSS into the UPS evidence-timeline framing as a *soft signal* and quantify how much early warning it provides before UPS reaches an Urgent Patch floor stage. The goal is not to “predict exploitation” in

the abstract, but to decide whether an EPSS alert justifies low-cost preparation work *before* the system is forced into an urgent state.

Contributions.

1. A time-relative evaluation of EPSS as an early-warning signal against an operational ground truth (Urgent Patch floor in UPS), with clear TP_early/FP definitions.
2. A Pareto analysis over threshold, persistence, and acceleration rules, yielding three operating points (WATCH/TRACK/PREPARE) plus an optional spike detector.
3. An empirical “stable-level” characterization: medians of percentile, EPSS score, and Δ percentile observed at TP_early alert time, showing separable regimes (broad, stable-high, extreme-tail, spike).

2 Background and related work (and why “just pick a threshold” is not a method)

EPSS reports (i) a probability score in $[0, 1]$ and (ii) a percentile rank among all scored CVEs at that date. The two numbers answer different operational questions[3, 4, 5]: probability is an absolute estimate; percentile is a ranking key. Treating percentile as probability (or vice versa) is a common category error, and it leads to magical thinking about “universal” cut-offs.

The larger problem is that remediation is not a classifier; it is a queue. A threshold is not merely a decision boundary; it is an arrival process definition. Once you admit items into the queue, finite capacity and cadence determine when (or whether) anything gets done. The “Meets Patch Queues” series exists because this is where the comforting spreadsheet dies.

Recent work increasingly treats prioritization as a multi-objective decision problem that combines exploit likelihood, known-exploitation evidence, technical impact, compliance deadlines, and operational effort. For example, RiskBridge proposes a compliance-aware, business-aligned framework that integrates EPSS, KEV, and CVSS into auditable prioritization and optimization logic[6]. Related integrated approaches combine KEV-style evidence, EPSS-style prediction, and CVSS-style impact into explicit decision trees or chaining workflows[7], while other lines of work emphasize context-aware scoring inside an organization’s risk workflow[8] or dependency-aware sequencing in complex environments[9].

We build on Paper I (UPS phase queues) and Paper II (EPSS-only gates), and we take the broader point that scoring systems can disagree in practice[10], and keep the same guiding principle: if a claim cannot survive calendar time, it is not an operational claim.

3 Data

3.1 UPS timelines and the 2025 evaluation window

We use UPS timelines produced by a signal collection pipeline over public artifacts (advisories, PoCs, detection content, exploited-catalog additions, etc.). Timelines may include events prior to 2025; these are retained to initialize state. Evaluation metrics are computed within the 2025 window [2025-01-01, 2026-01-01).

3.2 Weekly EPSS snapshots

We use weekly EPSS snapshot files for 2025. Each snapshot provides a score and a percentile per CVE. We compute one-week percentile change $\Delta p_t = p_t - p_{t-1}$.

3.3 Social and news attention signals (CIRCL sightings)

To study whether *attention* can compensate for late availability of “strong” UPS evidence (PoCs, exploit modules, detections, vendor “confirmed ITW” statements, etc.), we use CIRCL’s *Vulnerability-Lookup* “sightings” as a proxy for community and news attention[11]. Sightings aggregate public references across sources and provide a first-seen timestamp and a source domain.

We focus on a *late-knowledge* slice of the KEV-2025 set where the first available strong UPS signal is on/after `dateAdded` (or effectively the same week). For the subset where raw sightings were collected, the analysis cohort contains $N = 41$ CVEs.

4 Methods

4.1 Ground truth: “positive” as an operational floor event

For each CVE, we define a *positive event time* t^+ as the first time the UPS floor stage reaches **Urgent Patch** (or higher) within the evaluation window. This is intentionally operational: it corresponds to the point at which the system’s policy declares “patch now” rather than “monitor and prepare.”

4.2 Signal rules

We evaluate two rule families.

Percentile threshold with persistence.

$$\text{alert at } t \iff p_t \geq P \text{ for } k \text{ consecutive weeks}$$

where P is a percentile threshold and k enforces stability (anti-flapping).

Acceleration (spike) rule (optional).

$$\text{alert at } t \iff (p_t \geq P) \wedge (\Delta p_t \geq \Delta P)$$

This is explicitly not “better” than stability; it is a different regime: detect abrupt changes and treat them as a separate signal type.

4.3 Metrics

A rule trigger at time t_a is a **TP_early** if $t_a < t^+$ and t_a falls within the evaluation window. A trigger is a **FP** if it fires on a CVE that does not become positive in 2025.

We report:

- **Early recall** = $\text{TP_early} / N_{\text{pos}}$
- **Early precision** = $\text{TP_early} / (\text{TP_early} + \text{FP})$
- **FP/positive** = $\text{FP} / N_{\text{pos}}$ (queue inflation proxy)
- **Lead time** $\ell = t^+ - t_a$ (days), summarized by median, p10, p90 for TP_early cases.

4.4 Pareto selection of operating points

We grid-search candidate rules and compute a Pareto trade-off between early recall and FP/positive. Rather than declare one “optimal” threshold, we select three operating points to match different operational intents:

- **WATCH+**: coverage-oriented gate for low-cost monitoring work.
- **TRACK+**: stability-oriented gate ($k = 2$) to reduce noise from week-to-week variability.
- **PREPARE+**: precision-oriented extreme tail gate to admit a small, high-confidence set.
- **PREPARE_ACCEL+** (optional): spike detector (Δp) for abrupt changes under very low FP/positive.

4.5 Attention boundaries for social/news signals (KEV-driven workflow)

Social and news channels can be earlier than catalogs, but they are also noisy and gameable. For UPS we treat them as **PREP accelerators**, not as automatic Ops triggers. We define three practical *boundaries* over sightings in the 30 days preceding `dateAdded`:

- **Boundary A: Trusted non-social.** At least one sighting from a trusted, non-social domain (e.g., CERT/CSIRT/NCSC, MSRC, ZDI, Shadowserver, FortiGuard)[12, 13, 14].
- **Boundary B: Diversified non-social.** Sightings from ≥ 2 independent non-social domains (regardless of volume).
- **Boundary C: Buzz threshold.** Total mentions ≥ 10 , distinct domains ≥ 5 , active on ≥ 3 distinct days (use with caution).

For each boundary, an alert at time t_a is *early* if $t_a < t_{\text{KEV}}$ where $t_{\text{KEV}} = \text{dateAdded}$. We summarize (i) how many CVEs trigger each boundary and (ii) lead time $\ell = t_{\text{KEV}} - t_a$ (days).

5 Results (Urgent Patch floor, 2025 window)

5.1 Operating points

Table 1 reports the selected operating points on the Urgent Patch floor ground truth ($N_{\text{pos}} = 308$).

Table 1: Selected operating points (Urgent Patch floor, 2025 window).

Policy	Rule	Recall	Precision	FP/pos	Lead time (days)
WATCH+	$p \geq 0.30, k = 1$	0.192,0	0.118,0	1.429,0	median 21.0; p10 2.82; p90 122.6
TRACK+	$p \geq 0.85, k = 2$	0.074,7	0.134,5	0.481,0	median 15.82; p10 3.20; p90 145.10
PREPARE+	$p \geq 0.95, k = 1$	0.055,2	0.242,9	0.172,0	median 18.91; p10 1.49; p90 107.65
PREPARE_ACCEL+	$p \geq 0.95, \Delta p \geq 0.02, k = 1$	0.029,2	0.264,7	0.081,2	median 21.0; p10 5.27; p90 169.30

5.2 Pareto trade-off: early recall vs queue inflation

Figure 1 shows the Pareto map over evaluated rules, with the selected operating points highlighted. This is the policy choice in its most honest form: you can buy recall with workload, and you can buy workload control with missed early warnings. You cannot buy both without changing the sensing layer or the definition of “positive.”

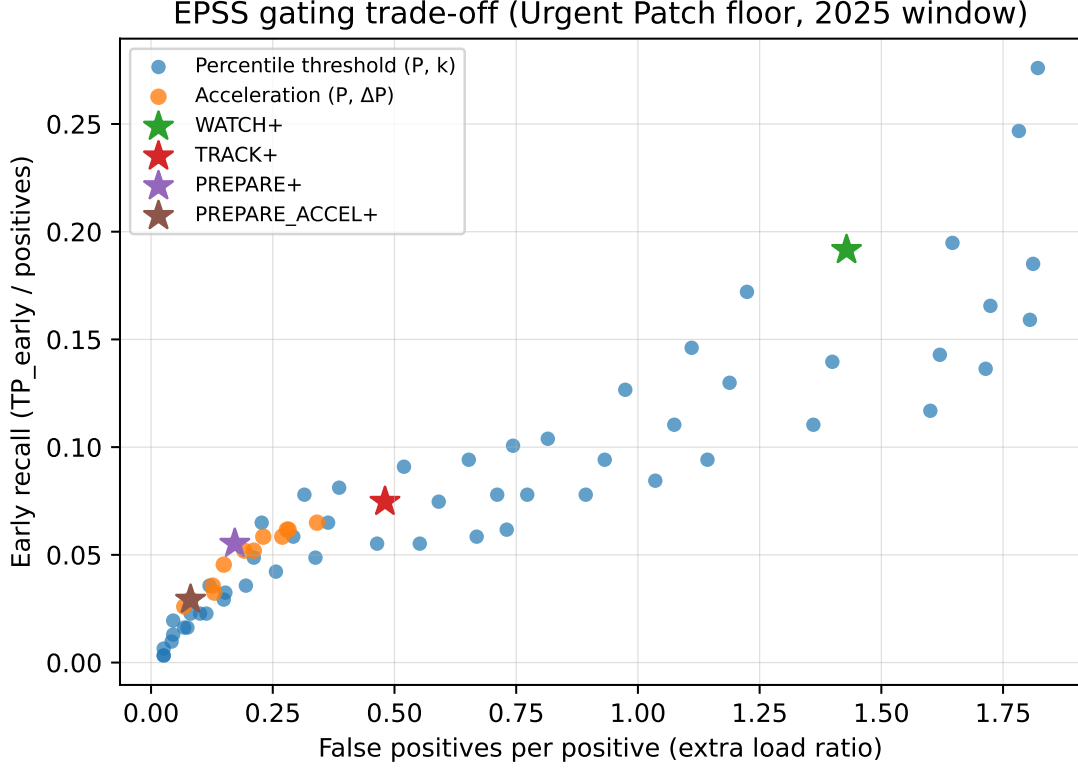


Figure 1: Pareto map (Urgent Patch floor): early recall vs FP/positive (extra load ratio), with selected operating points.

5.3 Stability helps: persistence k as anti-noise engineering

Figure 2 quantifies the effect of requiring persistence for threshold rules. The key observation is that $k = 2$ moves us into a “stable-high” regime: high percentile with negligible week-to-week change among TP_early alerts. This is not a philosophical statement; it is a mechanism to reduce admissions triggered by transient rank noise.

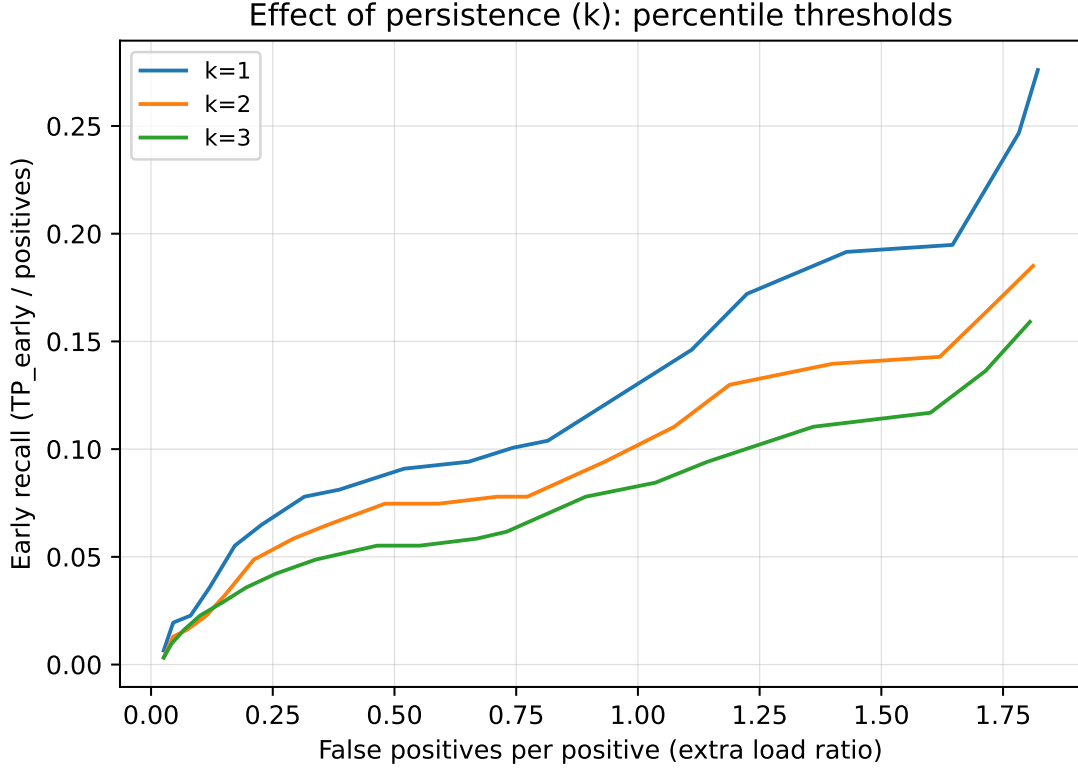


Figure 2: Effect of persistence k on the recall-load trade-off for percentile-threshold rules.

5.4 Stable-high vs spike: Δ percentile separates regimes

Figure 3 compares the empirical distributions of Δ percentile at alert time for TP_early vs FP across operating points. TRACK+ sits in a “stable-high” regime (high percentile, very small Δp); PREPARE_ACCEL+ explicitly targets large Δp spikes.

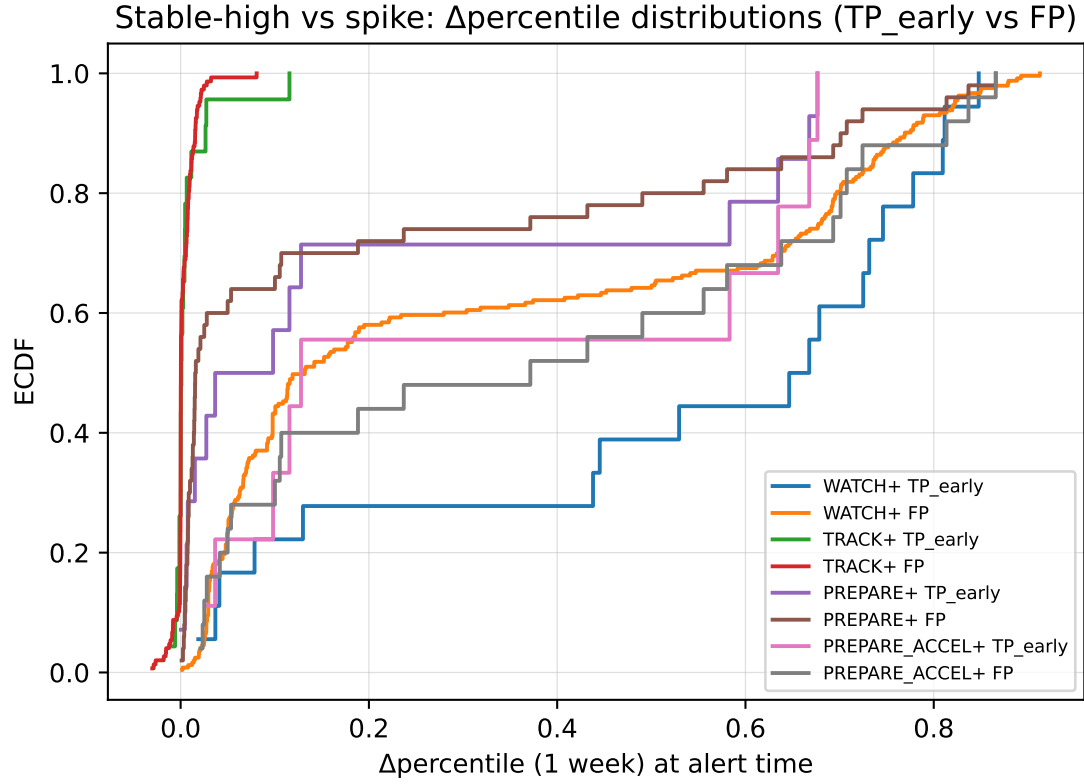


Figure 3: ECDF of Δ percentile at alert time for TP_early vs FP, by operating point.

5.5 Lead time distributions

Figure 4 shows lead-time ECDFs for TP_early cases. The medians sit in the ~ 16 – 21 day band across points, while tails extend beyond 100 days. Tightening the gate reduces workload, but does not necessarily destroy lead time for the subset it still catches.

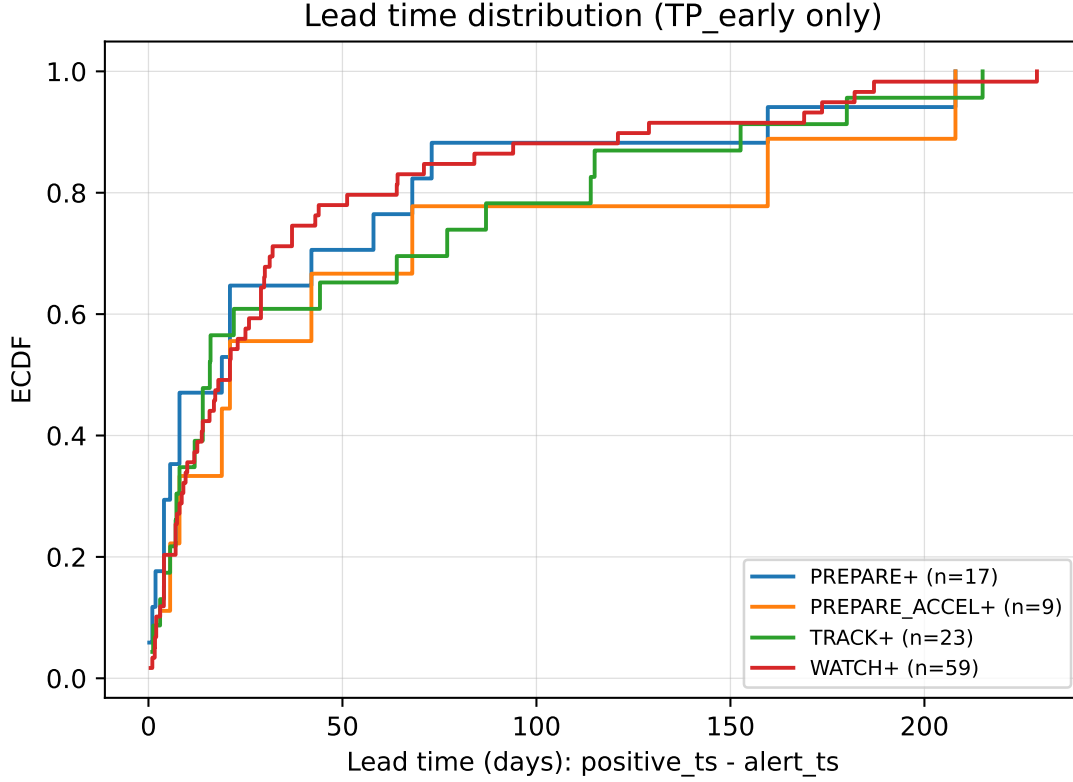


Figure 4: Lead-time ECDF for TP_early cases under selected operating points.

5.6 The ceiling effect: observability bounds early recall

Figure 5 illustrates a hard constraint: early recall is bounded by whether EPSS is observable before t^+ . If the first available EPSS snapshot occurs after the operational floor event, no threshold can generate an early alert. This is not an algorithm failure; it is an observability constraint.

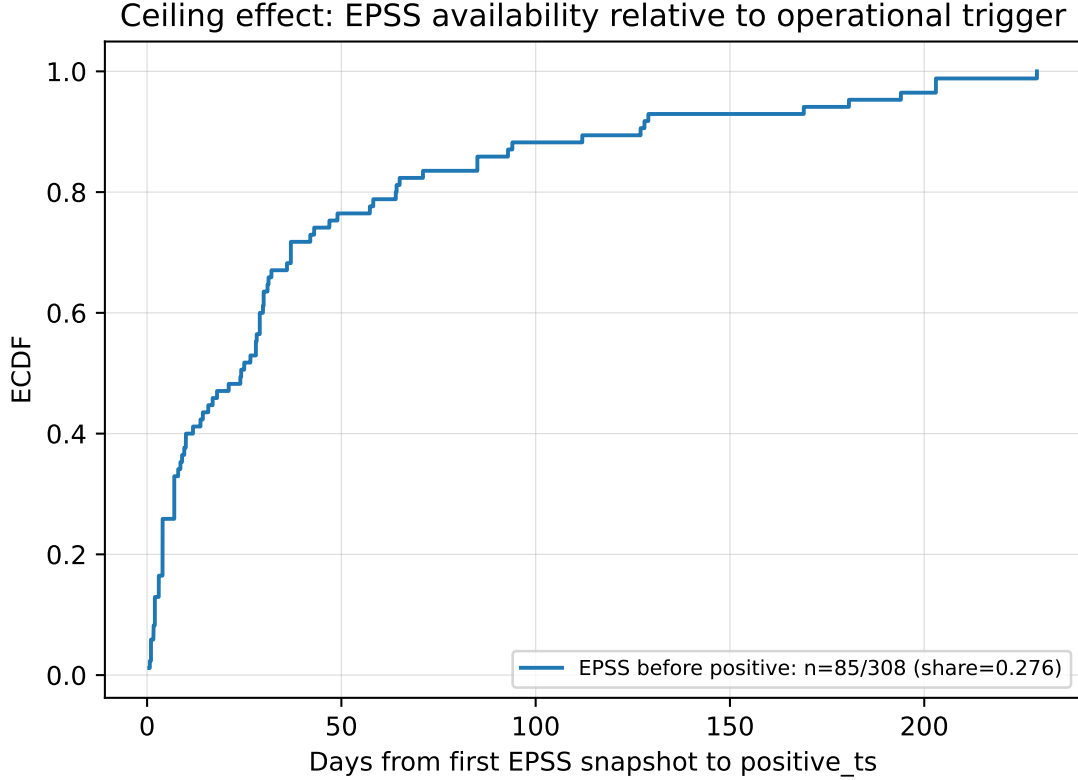


Figure 5: Ceiling effect: distribution of EPSS availability relative to the operational positive time.

5.7 “Stable levels” as empirical anchors

We summarize the medians of signal values at TP_early alert time. These are not hand-picked numbers; they are the empirical “temperature readings” at the moment EPSS produced useful early warnings:

- WATCH+: percentile median 0.567; EPSS median 0.0035.
- TRACK+ ($k = 2$): percentile median 0.943; EPSS median 0.158; Δ percentile median ≈ 0.00079 (stable-high).
- PREPARE+: percentile median 0.964; EPSS median 0.321; Δ percentile median 0.067.
- PREPARE_ACCEL+: percentile median 0.976; EPSS median 0.494; Δ percentile median 0.128 (spike regime).

5.8 Social/news signals: boundaries in the late-knowledge KEV slice

Table 2 summarizes how often attention boundaries trigger in the late-knowledge cohort ($N = 41$) and the resulting lead times before `dateAdded`. The main takeaway is sober: for KEV-late cases, *pure attention rarely buys much time*. When it does, it is typically due to authoritative non-social reporting or sustained, diversified coverage.

Table 2: Attention boundaries using CIRCL sightings (late-knowledge KEV slice, $N = 41$).

Boundary	Triggered (count)	Share	Lead time (days)
Any sightings	10	24%	(informational)
Any non-social sightings	6	15%	(informational)
Trusted non-social (A)	5	12%	median ~ 0.8 ; max 18
Diversified non-social (B)	3	7%	median ~ 0.39 ; max 18
Buzz threshold (C)	2	5%	median ~ 10.6 (n=2); max 18

Operationally, these boundaries should be interpreted as a *low-cost readiness trigger* (scoping, exposure checks, detection content readiness), with an explicit cap: social/news attention alone should not raise `stage_sticky` beyond Track unless corroborated by harder evidence.

6 Discussion (what this means for EPSS “best practices”)

6.1 EPSS as a gate vs EPSS as a signal

Using EPSS as a sole remediation gate implicitly demands that it behave like ground truth with low latency. It does not. The more defensible pattern (and the one consistent with how practitioners actually survive audits) is:

1. Evidence overrides (exploited-catalog, confirmed ITW, vendor confirmation) drive non-negotiable floors.
2. EPSS provides *soft admission hints* into low-cost preparation work, with explicit budgets for induced workload.

In other words: EPSS is an instrument; UPS is the flight control system. You may still crash, but at least you can explain why.

6.2 Why percentile dominates in practice (and why stability matters)

Percentile is attractive because exploitation is rare and rank ordering is convenient. But percentile is also sensitive to population shifts and weekly noise. TRACK+ demonstrates a simple stabilizer: require persistence $k = 2$. Empirically, this yields a regime with high percentile and negligible Δp , which aligns with the intuition of “consistently high risk” rather than “briefly exciting.”

6.3 Workload inflation is the price of early attention

FP/positive is an operationally legible proxy: false investigations per true urgent case in the cohort. WATCH+ buys coverage at a high inflation factor; PREPARE+ and ACCEL keep inflation low but catch fewer positives early. This is exactly the trade-off that threshold selection guidance hints at, but rarely quantifies against a time-relative operational ground truth.

6.4 A practical policy stack

A deployment-oriented interpretation is a tiered workflow:

- **WATCH+**: admit to monitoring/enrichment (cheap actions).
- **TRACK+**: admit to stable tracking (validation, exposure checks, preparation readiness).
- **PREPARE+**: admit to the limited “preparation budget” (change planning, targeted testing).
- **ACCEL+**: raise attention for abrupt percentile jumps (rare, low-noise).

The paradox is that this looks like “more process.” The reality is that it is *less* process than the one you will invent during an incident.

6.5 Stacking early-warning signals: EPSS stability meets attention boundaries

The two “early attention” channels studied here behave differently:

- **EPSS (percentile, stable-high).** A weekly probabilistic ranking signal. With persistence $k = 2$, it produces a stable-high regime that reduces flapping admissions.
- **Sightings (social/news).** A heterogeneous attention signal. Useful mostly when it comes from authoritative non-social sources, or when it is sustained and diversified.

A practical UPS stack is therefore:

1. **Hard floors** (exploited catalog, confirmed ITW, vendor confirmation) drive non-negotiable Urgent/Emergency triggers.
2. **EPSS operating points** (WATCH/TRACK/PREPARE/ACCEL) admit items into bounded preparation queues.
3. **Attention boundaries** admit items into the *lowest-cost* preparation tier (monitoring, enrichment, detection readiness), and may upgrade to Track only under corroboration.

This is not “more work”; it is work made explicit and budgetable[15].

7 Limitations

- **Ground truth is operational.** The Urgent Patch floor is an evidence-driven operational trigger, not a census of exploitation. This is a feature (we measure what the system acts on) and a limitation (it reflects evidence availability).
- **Weekly cadence.** Both EPSS and planning processes are observed in weekly steps; finer-grained dynamics are out of scope.
- **No asset context.** We do not filter by asset exposure or technology prevalence; workload inflation is therefore an upper bound.
- **Attention signals are noisy and partially observed.** Sightings are heterogeneous and can be manipulated; our KEV-late slice is a small cohort ($N = 41$) and should be interpreted as a directional operational sanity check, not a universal model.

8 Conclusion

If you use EPSS as a patch gate, it will sometimes arrive late, and you will blame your people. If you use it as a soft signal inside a phase machine, it becomes a controllable admission hint with measurable trade-offs. Our 2025 results show three usable operating points (WATCH/TRACK/PREPARE) and an optional acceleration detector. None of them is magic. The point is that they are *budgetable*.

Supplementary figures (selection workflow)

The following figures document the operating-point selection logic and the empirical anchor values observed at TP_early alert time.

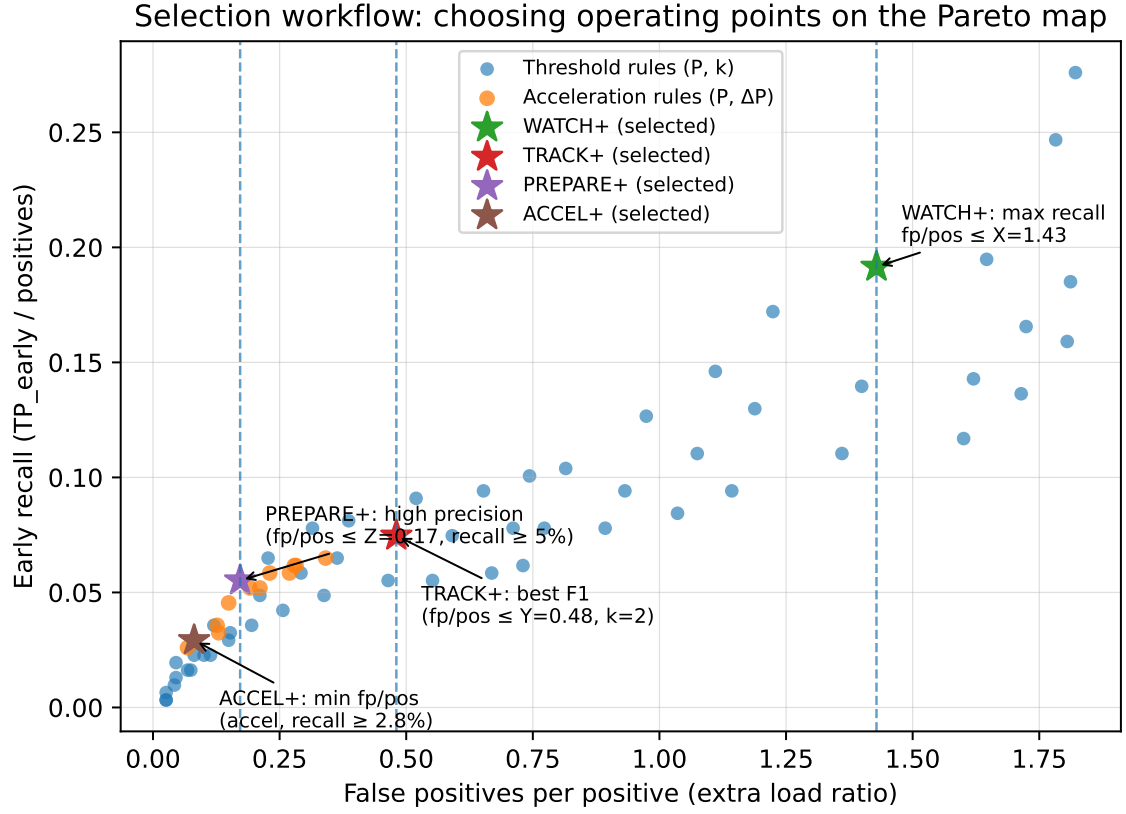


Figure 6: Selection workflow: operating points chosen on the Pareto map under explicit load envelopes.

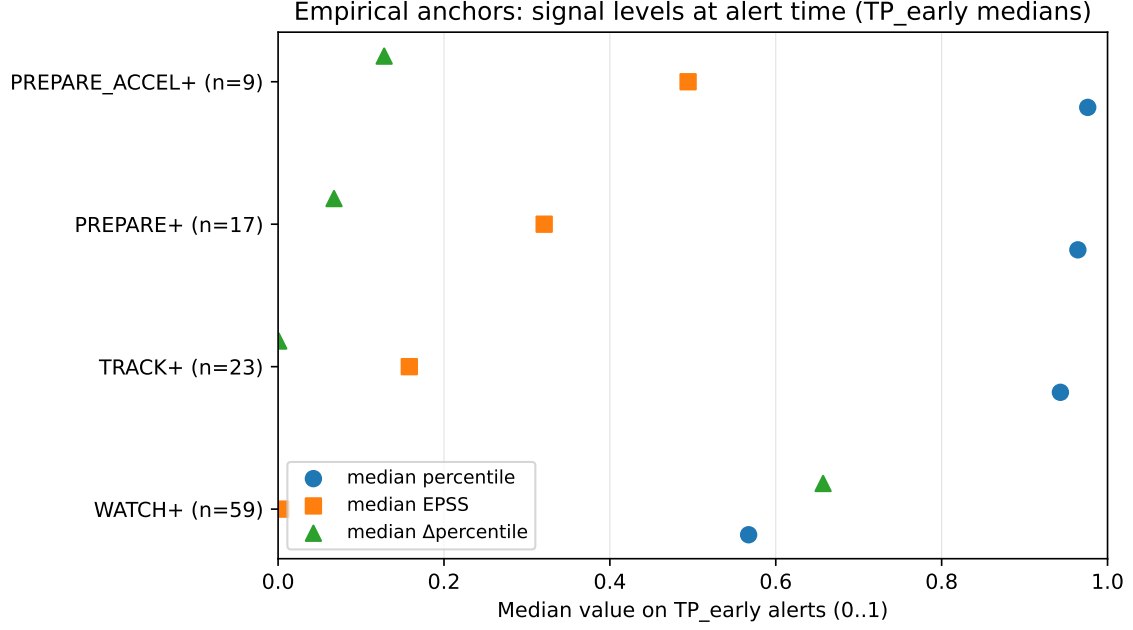


Figure 7: Empirical anchors: medians of percentile, EPSS score, and Δ percentile at TP_early alert time.

References

- [1] Sergey Gordeychik. *Prediction Meets Patch Queues: Empirical Limits of EPSS-Only Prioritization Using CISA KEV Additions in 2025*. Preprint. 2025.
- [2] Sergey Gordeychik. *UPS Meets Patch Queues: Evidence-timeline prioritization under limited capacity, cadence, and compliance gravity*. Preprint. 2026.
- [3] Jay Jacobs et al. “Exploit Prediction Scoring System (EPSS)”. In: *Digital Threats: Research and Practice 2.3* (2021). DOI: [10.1145/3436242](https://doi.org/10.1145/3436242).
- [4] *FIRST EPSS SIG: Exploit Prediction Scoring System (EPSS)*. <https://www.first.org/epss/>. Accessed 2025-12-30. 2025.
- [5] *FIRST EPSS SIG: Interpreting EPSS probabilities and percentiles*. https://www.first.org/epss/articles/prob_percentile_bins. Accessed 2025-12-30. 2025.
- [6] Yelena Mujibur Sheikh et al. *RiskBridge: Turning CVEs into Business-Aligned Patch Priorities*. arXiv:2601.06201. 2026.
- [7] Naoyuki Shimizu and Masaki Hashimoto. *Vulnerability Management Chaining: An Integrated Framework for Efficient Cybersecurity Risk Prioritization*. arXiv:2506.01220. 2025.
- [8] Abdulrahman Alhomidi, Mark Reed, and Stewart Kowalski. “CAVP: A context-aware vulnerability prioritization model”. In: *Computers & Security* 116 (2022), p. 102628. DOI: [10.1016/j.cose.2022.102628](https://doi.org/10.1016/j.cose.2022.102628).
- [9] Adeel Zaidi et al. “SmartPatch: A patch prioritization framework”. In: *Computers in Industry* 137 (2022), p. 103595. DOI: [10.1016/j.compind.2021.103595](https://doi.org/10.1016/j.compind.2021.103595).
- [10] Viktoria Kosciński et al. “Conflicting Scores, Confusing Signals: An Empirical Study of Vulnerability Scoring Systems”. In: *Proceedings of the 32nd ACM Conference on Computer and Communications Security (CCS 2025)*. Preprint: arXiv:2508.13644. 2025.
- [11] CIRCL. *Vulnerability-Lookup: Sightings API*. <https://vulnerability.circl.lu/sightings/>. Accessed 2026-01-29. 2026.

- [12] Carl Sabottke, Octavian Suci, and Tudor Dumitras. “Vulnerability Disclosure in the Age of Social Media: Exploiting Twitter for Predicting Real-World Exploits”. In: *24th USENIX Security Symposium (USENIX Security 15)*. 2015, pp. 1041–1056. URL: <https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/sabottke>.
- [13] Haipeng Chen et al. “Using Twitter to Predict When Vulnerabilities will be Exploited”. In: *Proceedings of the 25th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining (KDD '19)*. 2019, pp. 3143–3152. DOI: [10.1145/3292500.3330742](https://doi.org/10.1145/3292500.3330742).
- [14] Prasha Shrestha et al. “Multiple social platforms reveal actionable signals for software vulnerability awareness: A study of GitHub, Twitter and Reddit”. In: *PLOS ONE* 15.3 (2020), e0230250. DOI: [10.1371/journal.pone.0230250](https://doi.org/10.1371/journal.pone.0230250).
- [15] Sarah Elder et al. “A Survey on Software Vulnerability Exploitability Assessment”. In: *ACM Computing Surveys* 56.8 (2024). DOI: [10.1145/3648610](https://doi.org/10.1145/3648610).